IS08 — Secure Development Policy (DevSecOps)

[Company] IIoT Platform

Project name: [Company] Security Policies	Status: Active
Date: [Date]	Version: 1.0
Author: [Author Name]	Reviewer: [Reviewer Name]

Versions

Revision	Date	Author	Description
1.0	[Date]	[Author Name]	Initial release

Related Standards, Policies and Processes

- DevOps Policy for [Company] IIoT Platform
- [Company] Security Verification and Testing Process (IEC 62443-4-1)
- [Company] Software Deployment Security Process (IEC 62443-4-1)
- [Parent Company] - Software/Systems Development Life Cycle (SDLC) Policy

Definitions and Terms

Definitions and terms used in this policy follow the SANS Institute Glossary of Security Terms.

Overview

Implementing DevSecOps practices helps secure the product and the development environment. As a result, [Company] can deliver secure, high-quality products to customers and reduce the risk of threats introduced during the implementation phase.

Purpose

This policy establishes guidelines, principles and best security practices that govern security requirements and processes in development operations. It serves as a roadmap to align teams,

streamline workflows, and achieve the goals of Zero Trust and a secure development lifecycle for [Company].

Scope

All employees, contractors, consultants, temporary and other workers of [Company] working on the [Company] IIoT Platform must adhere to this policy. This policy applies to development operations (DevOps) maintained and run on the [Company] platform and its components.

This policy specifies requirements for developing and maintaining all [Company] platform products and the development environment.

Policy

Development Security Processes

Development should be separated into three independent environments: Main (Production), Beta and Dev.

The Development (Dev) environment is dedicated to the first phase of development and allows developers to build and test solutions from scratch.

The Beta environment is dedicated to testing of delivered solutions by the business team, to confirm that they comply with and fulfill the given requirements.

The Production environment provides fully operational products to customers. No testing should be performed in the production environment.

Development must follow the pipeline from the Development through Beta to Production environments. The Security Team must review project user stories, raise any security considerations and mark them as security-verified before delivery to the Beta stage.

To meet secure development requirements, the [Company] development pipeline includes:

1. Secret scanning covering all repositories and all branches
2. Dependency scanning covering all repositories and all branches
3. Static Application Security Testing (SAST) covering all repositories in development environments
4. Dynamic Application Security Testing (DAST) covering all web application repositories in the Beta environment

Access

Developers should have only the minimum access needed to the repositories they work on. Changes to the Production and Beta environments must go through the pipeline (see IS10); only the Development environment may be modified outside it. Each repository should have no more than two administrators, who are responsible for its maintenance.

All developers in the [Company]-[Dev Team] organization should be assigned to the appropriate organizational groups.

Access to repositories should be granted to groups, and to individual developers only when needed.

Continuous Integration and Continuous Delivery (CI/CD)

Deployment to infrastructure resources must be done through CI/CD pipelines, using dedicated service principals granted only the minimum access needed in the Azure environment.

Policy Compliance

Compliance Measurement

The Security Team will verify compliance with this policy through various methods, including but not limited to internal and external audits and feedback.

The Security Team measures the overall security state of the development environment and products using metrics provided by GitHub Advanced Security and GitHub Actions (SAST/DAST):

- Code Scanning alerts (CodeQL)
- DAST scanning reports (OWASP ZAP)
- Secret scanning alerts
- Dependency alerts (Dependabot)

Exceptions

Any exception to the policy must be approved by the Security Team in advance.

Non-Compliance

An employee found to have violated this policy may be subject to disciplinary action.